Cibersegurança - Segurança em Software (Módulo 2)
Trabalho Prático - Parte 3

Objetivos:
- Explorar diferentes vulnerabilidades de aplicações *web*, em contexto controlado
- Usar a ferramenta ZAP Proxy para realizar análise dinâmica (DAST) em aplicações *web*

Entrega:
- Respostas e evidências solicitadas no enunciado

A. Preparação

1. Execute a Juice Shop localmente, num contentor Docker, seguindo as instruções em https://github.com/juice-shop/juice-shop#docker-container. Para ter acesso a todos os desafios, inclua a variável de ambiente `NODE_ENV=unsafe`.

```
docker run --rm --env NODE_ENV=unsafe -p 127.0.0.1:3000:3000 bkimminich/juice-shop
```

   Confirme que consegue aceder à aplicação em http://localhost:3000.

2. Pode consultar todos os desafios que existem na aplicação acedendo ao URL http://localhost:3000/#/score-board.

3. Instale o ZAP (https://www.zaproxy.org) e inicie o browser a partir do ZAP ("Manual Explore" → *Launch Browser*). Este browser já confia no certificado do ZAP, por isso não é preciso instalar o certificado raiz no sistema.

4. Configure o âmbito e o modo: a) Aceda a http://localhost:3000 através do browser lançado pelo ZAP, para que a aplicação apareça na árvore de *Sites*. b) Clique com o botão direito no nó do site → *Include in Context* → *Default Context*. c) Mude o modo do ZAP (canto superior esquerdo) para Protected.

B. Injeção de SQL no *login*

5. Descreva e execute um ataque de injeção de SQL no formulário de *login*, tendo como alvo o utilizador *administrator*:

   https://pwning.owasp-juice.shop/companion-guide/latest/part2/injection.html#_log_in_with_the_administrators_user_account

6. Mostre o pedido HTTP feito à rota de login usando o mecanismo de interceção e análise de pedidos HTTP do ZAP.

C. Fuzzing da senha do administrador

7. Usando a ferramenta ZAP, descubra a senha do utilizador administrador `admin@juice-sh.op`. A senha começa com "admin" e termina num número com 3 algarismos. Mostre como usar a ferramenta de *fuzzing* para encontrar a senha correta.

8. Que requisito da OWASP ASVS 5.0 relativo a *brute force* está a ser violado? Que controlo o evitaria? (Sugestão: capítulo V6, *Authentication*.)

D. Broken access control

9. Usando a ferramenta ZAP, Mostre como resolver o desafio "*Post some feedback in another user's name*":

   https://pwning.owasp-juice.shop/companion-guide/latest/part2/broken-access-control.html#_post_some_feedback_in_another_users_name

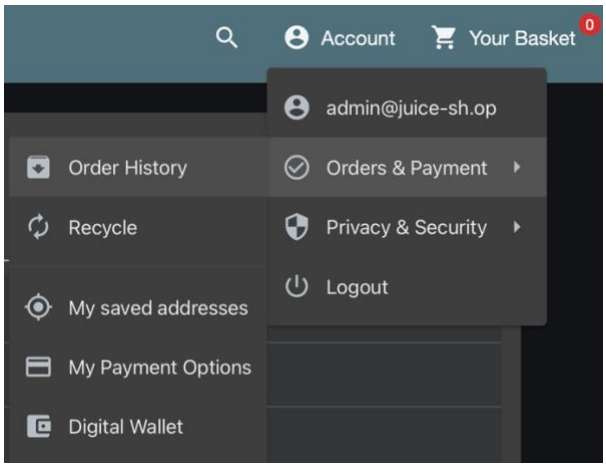
10. Este tipo de vulnerabilidades, conhecidas como Broken Object-Level Authorization (BOLA) ou Insecure Direct Object Reference (IDOR), estão em que posição na OWASP Top 10:2025?

11. Descreva sucientamente a vulnerabilidade identificada pelo CVE-2026-33760: https://www.cve.org/CVERecord?id=CVE-2026-33760.

E. Cross-site scripting (XSS)

12. Resolva o desafio "*Reflect XSS attack*" injetando o texto `<iframe src="javascript:alert(`xss`)">` para que o navegador tenha que processar uma página com o texto injetado (https://pwning.owasp-juice.shop/companion-guide/latest/part2/xss.html#_perform_a_reflected_xss_attack).

    Note que existe uma vulnerabilidade de XSS refletido na funcionalidade de seguimento de encomendas, http://localhost:3000/#/track-result  , acessível através lista de encomendas do utilizador, http://localhost:3000/#/order-history.



13. Explique a diferença entre XSS armazenado e XSS refletido.

14. Analise com as ferramentas do browser os cookies guardados pela aplicação. Analise o valor do cookie “token” com o site https://jwt.io e apresente o Payload em JSON.

15. Considere a vulnerabilidade de *cross-site scripting* (XSS) explorada no ponto 12:

    a. Descreva como é que usando engenharia social, um invasor poderia obter o *cookie* de nome "token", armazenado no navegador da vítima. Não é preciso executar cada uma das etapas, mas deve incluir uma explicação convincente do processo e descrever o que o "token" permite fazer.

    b. Descreva um possível vetor de ataque usando os fatores “vulnerability factors” e “technical impact factors” da metodologia OWASP para cálculo de risco (pode usar a calculador online https://owaspriskrating.com/).